

Table of Contents

Cisco Secure Workload — MAS Technology Risk Management Guidelines

Reference Design | Singapore Financial Institutions

Version: 1.0

Framework: Monetary Authority of Singapore (MAS) Technology Risk Management Guidelines (January 2021)

Use Case: Critical-system segmentation, technology asset inventory, third-party / outsourcing visibility, cyber security operations evidence

Framework version note. This reference design references the MAS TRM Guidelines published in January 2021, which remain the current published version at the time of writing. Validate against the latest MAS publication before using this reference design in a supervisory or audit context.

CSW UI navigation note. Cisco does not yet publish framework-specific CSW UI navigation for MAS TRM (it is on the product roadmap). This reference design references CSW *capabilities* and the *evidence artifacts* they produce. Where a specific CSW screen is named (e.g. "Inventory", "ADM workspace", "Policy workspace", "Flow Search", "Vulnerability Report"), it refers to the general-purpose CSW feature area, not a MAS-TRM-specific view.

Reader's Guide

Who this is for. Singapore-licensed financial institutions and regulated financial-services providers (banks, finance companies, insurers, capital markets services licensees, payment services licensees) using the MAS TRM Guidelines as the technology risk baseline. Useful for the CISO function, technology risk officer, infrastructure leads, and the compliance / internal audit teams that prepare for MAS supervisory engagements.

Questions this reference design helps you answer:

- *Can I demonstrate controlled workload connectivity into and out of critical systems and customer-data environments?* (Access Control, Data and Infrastructure Security)
- *Can I produce technology asset evidence that aligns with the institution's CMDB and the technology risk register?* (Technology Risk Management Framework)
- *Can I evidence vulnerability handling priorities for workloads in scope of critical or customer-data services?* (Cyber Security Assessment)

- *Can I reconcile outsourced / third-party communication paths against approved technology risk boundaries?* (Management of IT Services / Outsourcing)
- *If an investigation is needed, can I rebuild a workload-level communication and process timeline for the affected systems?* (Cyber Security Operations / Incident Management)

What you'll need. Current critical-systems list, outsourcing register, CMDB or cloud asset inventory, network architecture diagram, vulnerability management process, monitoring/SIEM retention policy, application owner contacts, and the institution's technology risk register.

Where to start. Sections 1–4 if you are scoping a deployment; sections 5–7 if you are ready to design and simulate policy; sections 9–10 if you are preparing for a MAS supervisory engagement or internal audit within the next quarter.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥ 2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Critical-system segmentation for Singapore financial sector
- Outsourcing/third-party egress reconciliation
- Incident investigation support from flow exports

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

The MAS TRM Guidelines are principle- and outcome-based supervisory guidance. They are not a control catalogue; they expect financial institutions to demonstrate that the technology risk management framework, including segmentation, monitoring, asset inventory, and incident response, is appropriate to the institution's risk profile.

Cisco Secure Workload (CSW) can support **technical evidence** for the TRM topics that depend on workload-level visibility, segmentation, policy enforcement, vulnerability context, telemetry, and forensic flow data. CSW does **not** replace MAS-level governance, board / senior management accountability, the technology risk management framework itself, BCP/DR, IAM, cryptography programme decisions, outsourcing due diligence, or regulatory notification.

MAS TRM Topics and CSW Relevance

MAS TRM topic area	CSW relevance
Technology Risk Management Framework	Workload inventory, labels, scopes, application identification
Management of IT Services (incl. outsourcing)	Third-party / outsourced service egress visibility

MAS TRM topic area	CSW relevance
IT Resilience	Approved-flow baseline as one input to resilience evidence
Access Control (network access layer)	Workload-level allowlist policy and audit
Data and Infrastructure Security	Micro-segmentation, plaintext-protocol detection
Cyber Security Operations	Flow / process telemetry, alerts, forensic search
Cyber Security Assessment	CVE / package exposure, reachability-informed prioritisation
IT Audit	Evidence packages from inventory, ADM, policy, and exception registers

Topics that are **out of scope** for CSW evidence (and must be evidenced by other tools, processes, or controls): governance and board oversight, cryptography module assurance, IAM/PAM lifecycle, BCP/DR testing, fraud risk, customer due diligence, supplier assurance contracts, and MAS reporting decisions.

2. Pre-Deployment Checklist

Before deploying CSW for a MAS-TRM-aligned use case, confirm:

- ☐ CSW cluster (SaaS or on-prem) provisioned and accessible
 - ☐ Network reachability from workloads to the CSW cluster on the documented control-plane port
 - ☐ Linux / Windows agent compatibility verified for representative critical systems
 - ☐ Cloud provider accounts connected via CSW cloud connectors where critical systems run in cloud
 - ☐ Critical systems list reviewed with the technology risk officer
 - ☐ Stakeholders identified: CISO, Technology Risk Officer, Application Owner(s), Internal Audit lead
 - ☐ Change management window approved for sensor / connector roll-out
 - ☐ Evidence retention period agreed with internal audit and the technology risk team
-

3. Phase 1 — Sensor & Connector Deployment (Days 1–5)

Deploy CSW telemetry sources without enforcement.

Software sensor install (representative pattern):

Linux (RHEL/CentOS/Ubuntu): install the CSW agent package distributed for the OS
Windows : install the signed CSW agent MSI

Initial sensor configuration:

- Enforcement Mode: **Monitoring Only** (no enforcement during Phase 1)
- Data collection: process context, network flow, package / vulnerability exposure (where supported by sensor type)
- Initial labels applied on Day 1: env, data_class, criticality, application, owner, compliance=mas-trm

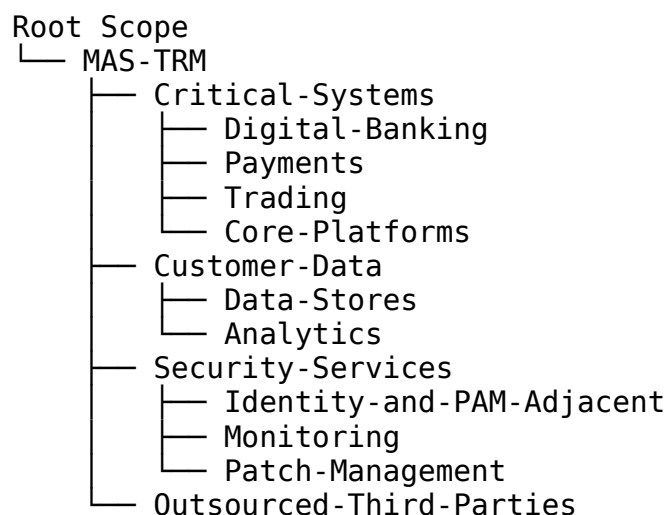
Cloud workload coverage (where applicable):

- Add cloud provider accounts (AWS / Azure / GCP) as CSW cloud connectors with read-only inventory and flow telemetry
- Confirm tag-based scope inheritance from cloud tags (e.g. application, environment, criticality, data_class)
- Document any workloads that **cannot** be instrumented (e.g. third-party managed PaaS) in a cannot-instrument register; this register is itself evidence

Sensor validation evidence: sensor inventory export with status, version, and last-checkin timestamp. Retain as Phase 1 baseline.

4. Phase 2 — Scope & Inventory Design (Days 6–10)

4.1 Suggested Scope Architecture



4.2 Inventory Filters

Build CSW inventory filters that auto-populate the scopes above. Examples:

Filter: Critical-Systems-Candidates

- Hostname / DNS contains: "core", "payments", "trade", "ledger"
- Tag (from CMDB sync): system_class = critical
- Process / port listened: domain-specific (e.g. ISO 8583, FIX, custom payment ports)

Filter: Customer-Data-Stores

- Listening process: mysqld, postgres, oracle, sqlserver, mongod
- Listening port: 1521, 3306, 5432, 1433, 27017
- Tag: data_class = customer

Filter: Outsourced-Third-Parties

- Source/Destination outside on-prem and cloud allow-lists
- Tag: managed_by = vendor

4.3 Labeling Strategy

Label key	Example values	Why it matters for MAS TRM
application	core-banking, payments-gateway, trading	Maps workloads to the institution's application register
env	production, uat, dev	Required to evidence segregation of environments
data_class	customer, internal, public	Supports data security and customer-information protection topics
criticality	critical, important, standard	Aligns to the institution's technology risk classification
owner	line-of-business, team	Accountability for control testing
compliance	mas-trm	Filters CSW evidence to MAS scope
vendor	<named vendor or "none">	Maps to outsourcing register

5. Phase 3 — Application Dependency Mapping (Days 11–21)

5.1 ADM Configuration

For each scope in 4.1, create an ADM workspace and run it across a representative business window that includes month-end and any batch processing cycles. Minimum observation window: 2 weeks; longer for batch-heavy services.

ADM workspace inputs to capture:

- Observed inbound and outbound flows (with process context where supported)
- Talker / listener clusters with proposed labels
- External endpoints (likely outsourced / third-party paths)

5.2 ADM Analysis for MAS TRM

Review the ADM output against the technology risk register. Document, per application cluster:

Question	MAS TRM topic
Which workloads receive connections from outside the Critical-Systems scope?	Access Control
Which database flows are encrypted vs. plaintext?	Data and Infrastructure Security
Which systems reach Outsourced-Third-Parties endpoints?	Management of IT Services
Are there unexpected lateral connections inside Critical-Systems?	Cyber Security Operations
Which workloads talk to Security-Services (identity, monitoring, patching)?	IT Resilience

5.3 Classification and Re-Scoping

1. Export the ADM clusters and review with each application owner.
2. Confirm which clusters are Critical-Systems vs. supporting services.
3. Apply or correct labels (application, data_class, criticality) in CSW.
4. Move workloads into the correct scope.
5. Re-run ADM against the corrected scope to produce the candidate policy.

6. Phase 4 — Policy Development (Days 22–35)

6.1 MAS-Aligned Policy Framework

Absolute (always-enforced) policies:

DENY Any inbound)	→ Critical-Systems	(default deny
DENY Critical-Systems internet egress from critical workloads)	→ Internet	(no direct
DENY Corporate-IT only via approved jump points)	→ Critical-Systems	(admin paths

Allowlist policies (least privilege; examples to adapt per application):

ALLOW Channel-Layer	→ Payments-Gateway	tcp/443
ALLOW Payments-Gateway tls-only>	→ Core-Banking-DB	tcp/<db-port-
ALLOW Core-Banking (LDAPS), tcp/88 (Kerberos)	→ Identity-Adjacent	tcp/636
ALLOW Jump-Hosts tcp/3389 (admin only)	→ Critical-Systems	tcp/22,
ALLOW Critical-Systems (telemetry egress)	→ Monitoring-Stack	tcp/443

Catch-all (audit everything else):

LOG Any trigger alert)	→ Critical-Systems	(unmatched flows
LOG Critical-Systems	→ Any	(unmatched outbound)

6.2 Policy Workspace Lifecycle

Phase	Mode	Duration	Purpose
1	Simulation	2 weeks	Validate the candidate policy against live traffic; tune false positives
2	Enforcement (high-confidence rules only)	1 week	Enforce only clear-cut policies (e.g. internet egress deny)
3	Full Enforcement	Ongoing	Workload allowlist enforced; exceptions reviewed monthly

Treat the policy workspace itself as evidence: export the workspace snapshot at the end of each phase and at every formal change.

7. Phase 5 — Topic Mapping with CSW Evidence

MAS TRM topic	What CSW produces	How to use it
Technology asset inventory	CSW workload inventory; scope and label export	Reconcile against the institution's CMDB / asset register
Information security risk assessment	Vulnerability exposure report scoped to the workload set	Provide reachability and exposure context to the risk register

MAS TRM topic	What CSW produces	How to use it
Access control (network access layer)	Policy workspace report; enforced allowlist and exception register	Show that workload-to-workload paths require explicit approval
Data security	Plaintext-flow detection from observed flows	Identify unencrypted protocols on regulated paths
Vulnerability management	CVE / package exposure with reachability context	Prioritise patching of internet-reachable or critical-system-reachable workloads
Security monitoring	Flow + process telemetry, anomaly alerts, SIEM export	Demonstrate detection coverage of critical-system flows
Cyber security operations	Forensic flow and process search across the incident window	Rebuild a workload-level communication timeline for an investigation
Management of IT services / outsourcing	Outbound flow summary to third-party endpoints	Reconcile against the outsourcing register and contractual scope
IT audit	Periodic evidence pack (sections 10.1–10.2)	Audit work-paper input

8. Phase 6 — Vulnerability & Risk Management

CSW vulnerability data is one input among threat intelligence, impact, control testing, and operational risk evidence. It should not be presented as the institution's full risk assessment.

Prioritisation pattern (adapt to the institution's risk appetite):

Priority 1: Critical CVE on Critical-Systems with inbound reachability
→ patch / mitigate within agreed SLA
Priority 2: High CVE on Critical-Systems
→ patch / mitigate within agreed SLA
Priority 3: Critical CVE on supporting workloads with reach to Critical-Systems → mitigate or restrict path

Compensating controls in CSW (when patch is delayed): restrict the vulnerable port to approved sources only, add an anomaly alert on the affected process, log all connections to the affected workload, and document the exception in the workspace exception register.

9. Phase 7 — Monitoring & Alerting

9.1 MAS-Relevant Alerts

Alert	Trigger	MAS TRM topic
Unauthorised reach to Critical-Systems	Any unapproved source → Critical-Systems	Access Control
Plaintext protocol detected on customer-data path	HTTP / FTP / unencrypted DB protocol from Customer-Data	Data Security
Lateral movement inside Critical-Systems	New east-west flow that wasn't in the approved baseline	Cyber Security Operations
External egress from Critical-Systems	Critical-Systems → external endpoint outside the allow-list	Outsourcing / IT Services
Policy violation	Enforced policy block triggered	Access Control
Vulnerability spike	New Critical CVE on a Critical-Systems workload	Cyber Security Assessment
Sensor offline	Agent stops reporting	Monitoring evidence integrity

9.2 Forensic Telemetry

For investigation, CSW retains the flow and process telemetry needed to rebuild a workload-level timeline. The investigation pack should contain:

- Flow log scoped to the affected workload(s) and time window (with process context)
- Process search output for the same window
- Policy workspace state at the time of the incident
- Vulnerability snapshot for the affected workload(s)

Retain investigation packs per the institution's retention policy and any MAS supervisory expectations.

10. Reporting & Evidence Collection

10.1 Evidence per Audit / Supervisory Cycle (quarterly recommended)

Evidence item	CSW source area	MAS TRM topic supported
Workload inventory	Inventory and scope	Technology asset

Evidence item	CSW source area	MAS TRM topic supported
snapshot	export	inventory
Scope and label membership	Scope membership export	Tech risk classification
Approved vs. observed flow comparison	ADM workspace export	Access Control / Data Security
Policy workspace snapshot	Policy workspace export	Access Control
Policy enforcement / violation log	Policy analysis output	Cyber Security Operations
Vulnerability exposure report	Vulnerability report scoped to MAS-TRM	Cyber Security Assessment
Third-party egress summary	Flow search filtered to outsourced endpoints	Management of IT Services
Incident timeline sample	Flow + process search for a representative incident	Cyber Security Operations
Exception register	Policy workspace exceptions list	Risk acceptance evidence

10.2 Ongoing Compliance Posture

- **Monthly:** scope / inventory review (workloads joining or leaving Critical-Systems); third-party egress review against the outsourcing register
- **Quarterly:** policy workspace review (validate rules still reflect current ADM); refresh evidence pack 10.1
- **Annually:** independent walk-through with internal audit; refresh the documented assumptions and CSW configuration baseline
- **Continuously:** policy drift detection (compare current workspace to last approved baseline); ADM re-run every 90 days

11. Common Pitfalls

Pitfall	Mitigation
Treating CSW evidence as the institution's risk assessment	CSW is one input; the technology risk register and risk appetite are governance artefacts
Critical workloads missing labels because CMDB is stale	Reconcile CMDB ↔ CSW inventory monthly; treat label hygiene as a control
Scope set too broad (subnet-based) instead of workload-based	Use process + label identity for scope membership, not just IP

Pitfall	Mitigation
ADM run too short and missing month-end / batch flows	Minimum 2-week observation; align to business cycles
Outsourced PaaS / SaaS treated as instrumented	Maintain a cannot-instrument register; document compensating controls
Enforcement applied before simulation	Always run Simulation first; stage enforcement scope-by-scope
Plaintext protocols allow-listed because of port-only rules	Identify protocols by process + observed handshake, not port number

Related Frameworks in This Repository

- [ISO/IEC 27001:2022](#) — many MAS-TRM-aligned institutions already operate under ISO 27001; the ISMS controls overlap with TRM topics
- [SOC 2 Type II](#) — relevant where the institution also delivers services to other regulated parties
- [PCI DSS v4.0](#) — payment-flow segmentation overlaps with MAS-TRM critical-system segmentation
- [NIST SP 800-53 Rev 5](#) — a useful technical control reference for MAS topic-to-control alignment

Document prepared for Cisco financial-services engagements. Replace [Customer Name], specific application names, and any bracketed fields before customer delivery. Validate control references against the current MAS TRM publication and the institution's compliance team.